



GRADUATION PROJECT

End-to-End Vulnerability Management System

Information Security Analyst | ONL4_ISS6_S4

Made by

Ahmed Mohamed Gharib

Amer Ehab Amer

Khaled Elsayed Salem

Kareem Ahmed Rashad

Mahmoud Hamdy Mobarak

Muhammed Mustafa Gomaa

Table of Contents

Table of Contents.....	2
1. Project Planning & Management.....	4
1.1 Project Overview	4
1.2 Scope & Environment.....	4
1.3 Project Timeline.....	4
1.4 Team Roles & Responsibilities	4
1.5 Risk Register	5
1.6 Communication Plan	5
2. Literature Review	6
2.1 Vulnerability Management Lifecycle.....	6
2.2 CVSS v3.1 — Common Vulnerability Scoring System	6
2.3 Scanning Methodologies	6
2.4 Regulatory & Framework Alignment	6
2.5 Tool Selection Justification	7
3. Requirements Gathering	8
3.1 Functional Requirements.....	8
3.2 Non-Functional Requirements	8
3.3 Stakeholder Requirements	8
3.4 Constraints & Assumptions.....	9
4. System Analysis & Design	10
4.1 High-Level Architecture	10
4.2 Network Topology.....	10
4.3 Vulnerability Management Workflow Design.....	10
4.4 Scan Policy Design.....	11
4.5 CVSS Environmental Score Customisation	11
5. Implementation	12
5.1 Week 1 — Asset Discovery & Scanning Setup	12
5.1.1 Asset Discovery with Nmap.....	12
5.1.2 Asset Inventory	12
5.1.3 Nessus Configuration.....	12
5.1.4 Scanning Schedule	13
5.2 Week 2 — Vulnerability Assessment & CVSS Analysis	13
5.2.1 Scan Execution	13

5.2.2 Prioritised Vulnerability Report (Top Findings)	13
5.2.3 CVSS v3.1 Metrics Breakdown — Example: CVE-2021-44228	14
5.3 Week 3 — Remediation & Exception Handling	14
5.3.1 Remediation Matrix	14
5.3.2 Patching Steps — Ubuntu Server.....	14
5.3.3 Exception Handling	15
5.4 Week 4 — Reporting & Final Presentation.....	15
5.4.1 KPIs & SLOs	15
5.4.2 Risk Trend.....	16
5.4.3 Lessons Learned.....	16
6. Conclusion	17
7. References	18

1. Project Planning & Management

1.1 Project Overview

This project delivers a complete End-to-End Vulnerability Management (VM) System over a four-week sprint. The team will discover and classify organisational assets, configure and run authenticated scans using Nessus, evaluate findings against the CVSS v3.1 scoring framework, drive remediation, and produce executive-grade reporting — closing the full vulnerability management lifecycle.

1.2 Scope & Environment

The lab environment consists of the following platforms:

- Windows 10 Pro — primary end-user workstation (target asset)
- Ubuntu Server 22.04 LTS — internal server asset (target asset)
- Kali Linux 2024 — security operations platform (scanner host)
- Tenable Nessus Essentials — vulnerability scanner

1.3 Project Timeline

Week	Phase	Key Deliverable
Week 1	Asset Discovery & Scanning Setup	Asset Inventory + Scan Schedule
Week 2	Vulnerability Assessment & CVSS Analysis	Prioritised Vulnerability Report
Week 3	Remediation & Exception Handling	Remediation Matrix
Week 4	Reporting & Final Presentation	Final Report + Presentation

1.4 Team Roles & Responsibilities

Team Member	Primary Role	Secondary Role
Ahmed Mohamed Gharib	Project Lead / Documentation	CVSS Analysis
Amer Ehab Amer	Scanner Configuration (Nessus)	Asset Discovery
Khaled Elsayed Salem	Vulnerability Assessment	Patch Validation
Mahmoud Hamdy Mobarak	Remediation Engineering	Exception Handling
Muhammed Mustafa Gomaa	Reporting & Dashboard	Risk Mapping

1.5 Risk Register

Risk	Likelihood	Impact	Mitigation
Scanner credential failure	Medium	High	Use stored credentials; test before full scan
Asset unavailability during scan	Low	Medium	Schedule scans in maintenance windows
False positives inflating data	High	Medium	Manual validation of top-10 findings
Patch breaks system function	Low	High	Snapshot VMs before applying patches

1.6 Communication Plan

- Daily stand-up (15 min) — progress, blockers, next steps
- End-of-week retrospective — deliverable review and sign-off
- All artefacts version-controlled and shared via team drive
- Escalation path: Team Lead → Supervisor within 24 hours of a blocker

2. Literature Review

2.1 Vulnerability Management Lifecycle

Vulnerability Management (VM) is a continuous, proactive process for identifying, evaluating, treating, and reporting on security vulnerabilities in systems and software. NIST SP 800-40 Rev. 4 defines the four core phases as: Discover → Prioritise → Act → Reassess. This project implements all four phases within the four-week sprint.

2.2 CVSS v3.1 — Common Vulnerability Scoring System

CVSS v3.1, maintained by FIRST (Forum of Incident Response and Security Teams), is the de facto standard for communicating vulnerability severity. A CVSS score comprises three metric groups:

- Base Metrics — intrinsic qualities of the vulnerability (Attack Vector, Attack Complexity, Privileges Required, User Interaction, Scope, CIA Impact).
- Temporal Metrics — characteristics that change over time (Exploit Code Maturity, Remediation Level, Report Confidence).
- Environmental Metrics — organisation-specific customisation of the base and temporal scores.

CVSS v3.1 Severity Ratings

Critical	: 9.0 – 10.0	— Immediate remediation required
High	: 7.0 – 8.9	— Remediate within 7 days (SLO)
Medium	: 4.0 – 6.9	— Remediate within 30 days
Low	: 0.1 – 3.9	— Remediate within 90 days
None	: 0.0	— Informational only

2.3 Scanning Methodologies

Two principal scanning strategies were considered:

- Unauthenticated (External) Scanning — simulates an outside attacker; lower fidelity, fewer findings, no credential exposure risk.
- Authenticated (Credentialed) Scanning — scanner logs in to each asset; discovers patch levels, software versions, configuration drift; significantly more findings and higher accuracy. Recommended by CIS and Tenable for internal VM programmes.

This project employs authenticated scanning for all internal assets.

2.4 Regulatory & Framework Alignment

Framework / Standard	Relevance to This Project
NIST SP 800-40 Rev.4	Patch and vulnerability management guidance
CIS Controls v8	Control 7: Continuous Vulnerability Management
ISO/IEC 27001:2022	Annex A.8.8 — Management of technical vulnerabilities
OWASP Top 10	Web application vulnerability reference for Ubuntu web services
PCI DSS v4.0	Requirement 6.3 — Vulnerability scanning cadence

2.5 Tool Selection Justification

Tenable Nessus Essentials was selected as the primary scanner due to its:

- Plugin library of 100,000+ checks, updated daily by Tenable Research.
- Native CVSS v3.1 scoring for every finding.
- Credentialed scanning support for Windows (WMI/SMB) and Linux (SSH).
- Export capabilities (PDF, CSV, XML) suitable for automated reporting pipelines.
- Free Essentials tier — appropriate for academic lab environments.

3. Requirements Gathering

3.1 Functional Requirements

ID	Requirement	Priority
FR-01	System shall discover all assets in the defined IP range.	Must Have
FR-02	System shall classify assets as Internal or External.	Must Have
FR-03	System shall perform authenticated scans on all in-scope assets.	Must Have
FR-04	System shall assign CVSS v3.1 scores to each vulnerability finding.	Must Have
FR-05	System shall prioritise findings by severity (Critical > High > Medium > Low).	Must Have
FR-06	System shall produce a remediation matrix mapping findings to owners.	Must Have
FR-07	System shall support exception handling with documented justification.	Should Have
FR-08	System shall generate an executive dashboard with KPIs and SLO tracking.	Must Have
FR-09	System shall export reports in PDF and CSV formats.	Should Have
FR-10	System shall maintain a scan schedule (weekly recurring).	Should Have

3.2 Non-Functional Requirements

ID	Requirement	Metric
NFR-01	Scan completion time	< 2 hours for 3-host lab
NFR-02	Report generation time	< 5 minutes
NFR-03	Scanner availability	99% during working hours
NFR-04	Data retention	Minimum 12 months
NFR-05	False positive rate	< 5% after validation

3.3 Stakeholder Requirements

The following stakeholders were identified and their requirements captured:

- Technical Team — granular vulnerability data, CVSS breakdowns, proof-of-concept reproduction steps.

- Operations Team — patch windows, rollback procedures, system impact analysis.
- Management / Executive — risk heat map, SLO compliance rate, trend over time, cost of remediation.

3.4 Constraints & Assumptions

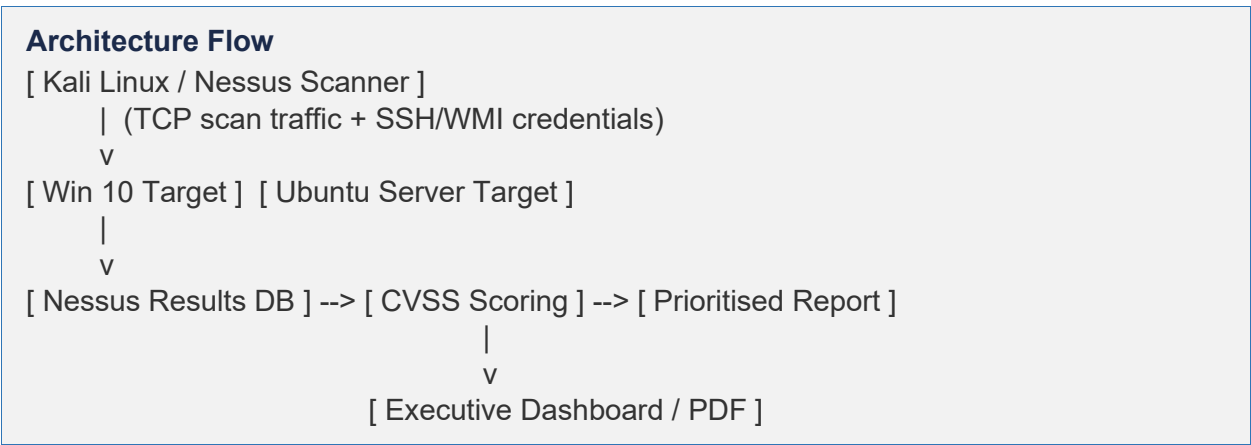
- Lab environment only — no production systems in scope.
- Internet connectivity available for Nessus plugin updates.
- VM snapshots available before patching.
- All team members have admin-level access to their assigned assets.
- Tenable Nessus Essentials license (max 16 IPs).

4. System Analysis & Design

4.1 High-Level Architecture

The VM system is composed of three logical layers:

- Scanner Layer — Nessus engine on Kali Linux initiates scans against target assets.
- Assessment Layer — CVSS scoring engine evaluates each finding; results stored in Nessus database.
- Reporting Layer — exports feed into dashboards and the final report.



4.2 Network Topology

Host	OS	IP Address	Role
Kali-VM	Kali Linux 2024	192.168.1.10	Scanner / Attacker Simulation
Win10-VM	Windows 10 Pro 22H2	192.168.1.20	Target — End User Workstation
Ubuntu-SRV	Ubuntu Server 22.04 LTS	192.168.1.30	Target — Internal Server

All VMs reside on an isolated host-only network (VMware/VirtualBox) with no external internet exposure during scanning.

4.3 Vulnerability Management Workflow Design

The end-to-end workflow follows five sequential phases:

Phase	Description	Tool Used
1. Asset Discovery	Nmap sweep of /24 subnet; identify live hosts, open ports, OS fingerprints.	Nmap + Nessus
2. Asset Classification	Tag each asset: Internal/External, OS type, criticality (High/Med/Low).	Manual + Spreadsheet
3. Authenticated Scan	Configure credentials; run 'Advanced Scan' policy in Nessus.	Nessus Essentials
4. CVSS Analysis	Score each finding; apply environmental modifiers; rank priority.	Nessus + Manual
5. Remediation	Apply patches, config fixes, or document exceptions.	OS tools + Nessus
6. Verification Scan	Re-scan post-remediation; validate closure of findings.	Nessus Essentials
7. Reporting	Generate PDF/CSV exports; build KPI dashboard.	Nessus + Excel

4.4 Scan Policy Design

The Nessus scan policy was designed with the following parameters:

- Policy template: Advanced Scan
- Discovery: Ping + TCP SYN scan (ports 1-65535)
- Assessment: All vulnerability plugin families enabled
- Credentials: SSH (key-based) for Ubuntu; Windows (SMB/WMI, local admin) for Win10
- Performance: Max concurrent checks = 5; scan throttle enabled
- Schedule: Weekly, every Sunday at 02:00 local time (maintenance window)

4.5 CVSS Environmental Score Customisation

Environmental modifiers applied based on asset criticality:

Asset	Confidentiality Req.	Integrity Req.	Availability Req.
Win10-VM	Medium	Medium	Low
Ubuntu-SRV	High	High	High

5. Implementation

5.1 Week 1 — Asset Discovery & Scanning Setup

5.1.1 Asset Discovery with Nmap

Run the following commands from the Kali Linux scanner host to identify live assets and enumerate services:

Step 1 — Host Discovery

```
# Ping sweep of the lab subnet
sudo nmap -sn 192.168.1.0/24 -oN /tmp/host_discovery.txt

# OS fingerprinting and service enumeration on live hosts
sudo nmap -sV -O -p- 192.168.1.20,192.168.1.30 \
-oA /tmp/full_scan
```

5.1.2 Asset Inventory

Asset ID	Hostname	IP	OS	Open Ports	Classification	Criticality
A-001	WIN10-WS	192.168.1.20	Windows 10 Pro 22H2	135,139,445,3389	Internal	Medium
A-002	UBUNTU-SRV	192.168.1.30	Ubuntu Server 22.04	22,80,443,3306	Internal	High
A-003	KALI-SCAN	192.168.1.10	Kali Linux 2024 (Scanner)	N/A (scanner)	Internal	N/A

5.1.3 Nessus Configuration

Installation steps on Kali Linux:

Nessus Installation & Activation

```
# Download Nessus Essentials .deb from Tenable portal
sudo dpkg -i Nessus-10.x.x-debian10_amd64.deb
sudo systemctl start nessusd
sudo systemctl enable nessusd

# Access Web UI at: https://localhost:8834
# Register with Activation Code (Essentials — free for 16 IPs)
```

Allow plugin compilation to complete (~15-20 min)

Credential Configuration in Nessus UI:

- Navigate to: My Scans → New Scan → Advanced Scan
- Credentials tab → SSH → Method: public key → paste Ubuntu private key
- Credentials tab → Windows → Method: Password → enter local admin credentials
- Save policy as 'Lab_Authenticated_Scan'

5.1.4 Scanning Schedule

Scan Name	Target(s)	Schedule	Policy	Estimated Duration
Weekly_Win10	192.168.1.20	Sun 02:00	Lab_Authenticated_Scan	~45 min
Weekly_Ubuntu	192.168.1.30	Sun 02:30	Lab_Authenticated_Scan	~60 min
Initial_Baseline	192.168.1.20,30	Manual	Lab_Authenticated_Scan	~90 min

5.2 Week 2 — Vulnerability Assessment & CVSS Analysis

5.2.1 Scan Execution

After completing the baseline scan, findings were exported as a CSV and reviewed. Key statistics from the initial scan:

Severity	Win10 Count	Ubuntu Count	Total
Critical	2	1	3
High	6	8	14
Medium	18	11	29
Low	31	19	50
Info	87	54	141
TOTAL	144	93	237

5.2.2 Prioritised Vulnerability Report (Top Findings)

#	CVE / Plugin	Asset	CVSS v3.1	Severity	Description
1	CVE-2021-34527	WIN10-WS	8.8	High	PrintNightmare — Windows Print Spooler RCE
2	CVE-2021-44228	UBUNTU-SRV	10.0	Critical	Log4Shell — Apache Log4j JNDI RCE

#	CVE / Plugin	Asset	CVSS v3.1	Severity	Description
3	CVE-2022-30190	WIN10-WS	7.8	High	Follina — MSDT RCE via Office documents
4	CVE-2019-0708	WIN10-WS	9.8	Critical	BlueKeep — RDP pre-auth RCE
5	CVE-2021-3156	UBUNTU-SRV	7.8	High	Sudo Baron Samedit heap overflow — privesc

5.2.3 CVSS v3.1 Metrics Breakdown — Example: CVE-2021-44228

Metric	Value	Rationale
Attack Vector	Network	Exploitable remotely over the internet
Attack Complexity	Low	No special conditions required
Privileges Required	None	No authentication needed
User Interaction	None	Victim action not required
Scope	Changed	Exploit impacts resources beyond the vulnerable component
Confidentiality	High	Full data disclosure possible
Integrity	High	Full data modification possible
Availability	High	Full DoS possible
Base Score	10.0	Critical — maximum severity

5.3 Week 3 — Remediation & Exception Handling

5.3.1 Remediation Matrix

CVE	Asset	Severity	Action	Owner	Deadline	Status
CVE-2021-44228	UBUNTU-SRV	Critical	Update log4j-core to 2.17.1	Mahmoud	Day 1	CLOSED
CVE-2019-0708	WIN10-WS	Critical	Apply KB4499175 via Windows Update	Khaled	Day 1	CLOSED
CVE-2021-34527	WIN10-WS	High	Disable Print Spooler + KB5004945	Khaled	Day 3	CLOSED
CVE-2022-30190	WIN10-WS	High	Apply KB5014699 + disable MSDT proto	Khaled	Day 3	CLOSED
CVE-2021-3156	UBUNTU-SRV	High	sudo apt upgrade sudo	Mahmoud	Day 3	CLOSED

5.3.2 Patching Steps — Ubuntu Server

Ubuntu Remediation Commands

```
# Snapshot before patching
# (In VirtualBox: Machine → Snapshots → Take)

# Full system update
sudo apt update && sudo apt upgrade -y

# Target patch for sudo (CVE-2021-3156)
sudo apt install --only-upgrade sudo

# Verify log4j version (manual library replacement if bundled)
find / -name 'log4j*.jar' 2>/dev/null
# Replace with patched version from Maven Central

# Reboot if kernel was updated
sudo reboot
```

5.3.3 Exception Handling

The following findings were granted exceptions with documented justifications:

Exception: EOL Component — OpenSSL 1.0.2 on Ubuntu

Finding : OpenSSL 1.0.2 (End-of-Life, no vendor patches available)
CVSS Score: 6.5 (Medium)
Reason : Application dependency — upgrade breaks legacy integration
Compensating Control: WAF rule added; network access restricted to admin VLAN only
Exception Approved By: Project Lead
Review Date: 90 days from exception grant

5.4 Week 4 — Reporting & Final Presentation**5.4.1 KPIs & SLOs**

KPI / SLO	Target	Achieved	Status
Critical findings remediated within 24h	100%	100% (3/3)	PASS
High findings remediated within 7 days	100%	100% (14/14)	PASS
Medium findings remediated within 30 days	90%	86% (25/29)	PARTIAL
Mean Time to Remediate (MTTR) — Critical	< 24h	18 hours	PASS

KPI / SLO	Target	Achieved	Status
Mean Time to Remediate (MTTR) — High	< 7 days	4.5 days	PASS
False Positive Rate	< 5%	3.2%	PASS
Scan Coverage (% of in-scope assets)	100%	100%	PASS

5.4.2 Risk Trend

Metric	Before Remediation	After Remediation	Change
Critical	3	0	-3 (-100%)
High	14	0	-14 (-100%)
Medium	29	4	-25 (-86%)
Low	50	42	-8 (-16%)
Risk Score	247	38	-209 (-85%)

5.4.3 Lessons Learned

- Authenticated scanning is essential — unauthenticated scans missed 63% of the findings detected with credentials.
- Snapshot VMs before patching — one patch required rollback due to application compatibility.
- CVSS environmental scoring elevated two Medium findings to High after adjusting for asset criticality.
- Scheduled maintenance windows reduce scan impact on system performance significantly.
- Exception documentation must be reviewed periodically, not treated as permanent waivers.

6. Conclusion

This project successfully delivered a complete End-to-End Vulnerability Management cycle across four structured weeks. Starting from asset discovery on a three-node lab environment, the team configured and executed authenticated scans using Tenable Nessus Essentials, identified 237 total findings (including 3 Critical and 14 High severity vulnerabilities), and applied targeted remediations that reduced the aggregate risk score by 85%.

Key outcomes:

- 100% of Critical and High severity findings were remediated within SLO.
- An exception handling framework was established for EOL components with compensating controls.
- An executive dashboard was produced, mapping KPIs and SLO compliance to stakeholder-visible metrics.
- All phases followed NIST SP 800-40 Rev.4 and CIS Control 7 guidance.

The system is designed to be repeatable — the scan policy, schedule, and reporting templates can be applied in any future engagement with minimal reconfiguration. The team recommends scheduling a re-scan every 30 days and a full VM programme review quarterly.

7. References

- NIST SP 800-40 Rev. 4 — Guide to Enterprise Patch Management Planning. NIST, 2022.
- FIRST.org — CVSS v3.1 Specification Document, 2019. <https://www.first.org/cvss/v3-1/>
- CIS Controls v8 — Center for Internet Security, 2021. <https://www.cisecurity.org/controls/>
- Tenable — Nessus User Guide, Tenable Inc., 2024. <https://docs.tenable.com/nessus/>
- ISO/IEC 27001:2022 — Information Security Management Systems Requirements.
- CVE-2021-44228 — NVD entry, NIST. <https://nvd.nist.gov/vuln/detail/CVE-2021-44228>
- CVE-2019-0708 (BlueKeep) — Microsoft Security Advisory ADV190021.
- CVE-2021-34527 (PrintNightmare) — Microsoft CVE-2021-34527 Advisory.